The governance *handbrake*.

How security councils solved DeFi's speed-versus-decentralization problem — and the new vulnerabilities they introduced.

Anay, Atharva, Ved

A pure DAO cannot outrun its own *bug*.

HOW $80M DRAINED

01 **Proposal 62** shipped a new COMP distribution model — approved by DAO vote.

02 A single flawed operator (> where >= was needed) let the contract release COMP without checking supply caps.

03 The moment the timelock ended and the upgrade went live, the contract began **paying out 280,000 COMP per transaction** to anyone who claimed.

04 Developers spotted it in minutes. But the only fix was another proposal — which triggered another **7-day timelock**.

05 For a week, the community watched the drain live on-chain. **$80M+ in COMP** was mistakenly claimed before the patch landed.

THE DRAIN
$80M

vs.

THE FIX
7 days
SPEED OF GOVERNANCE

Decentralized governance speed is *incompatible* with the speed of a smart-contract exploit.

A small, elected committee with *super-admin* keys — used rarely.

A multi-sig of trusted signers who bypass DAO voting delays in an emergency. Peacetime: routine maintenance. Wartime: instant intervention.

MECHANISM	Gnosis Safe multi-sig
BYPASS	Emergency role on the TimelockController — delay = 0
AUTHORITY	Pause · upgrade · execute arbitrary transactions

SIGNATURE THRESHOLD

9 of 12

Nine distinct private keys must sign. No single member, no small subset, can act alone.

Two routes to a state change.

STANDARD DAO ROUTE

Democratic. Deliberate.

01	Submit proposal	onchain
02	Community vote	3 days
03	Mandatory timelock	2–4 days
04	Execute state change	–

TIME TO ACT **7 days**

SECURITY COUNCIL ROUTE

Emergency. Instant.

01	Detect anomaly	monitoring
02	Coordinate signers	minutes
03	Gather 9 signatures	–
04	Execute with delay = 0	one block

TIME TO ACT **<1 hour**

Three emergency powers, ordered by *blast radius*.

I

CIRCUIT BREAKER

Protocol pause.

Instantly freeze deposits, withdrawals, or trading on specific contracts. Least destructive — stops the bleed without moving funds.

II

HOT PATCH

Contract upgrade.

Force an immediate logic change on a proxy contract to patch a vulnerability. Rewrites behaviour in a single block.

III

NUCLEAR OPTION

Arbitrary transaction.

Execute custom logic: intercept funds, blacklist malicious addresses, revert specific actions. Full sovereign reach over the protocol.

Where Compound failed, Arbitrum's council *acted*.

HOW $70M WAS SAVED

01 An exploit in Kelp DAO's restaking contracts began draining user deposits — **~$300M** siphoned across DeFi positions.

02 The attacker bridged **30,766 ETH (~$70M)** to Arbitrum as a holding wallet before attempting to launder it.

03 Arbitrum's Security Council detected the incoming funds. They skipped the 7-day vote and mobilised in minutes.

04 With 9 signatures, they executed a single atomic transaction on Ethereum mainnet that **intercepted the ETH mid-flight** — before the attacker could move it again.

05 Funds were routed to a DAO-controlled recovery address. **Zero network downtime, zero collateral damage.**

CASE STUDY · EXPLOIT & RECOVERY

Kelp DAO

$70M *recovered*

EXPLOIT TOTAL	~$300M across positions
ETH INTERCEPTED	30,766 ETH on Arbitrum
DAO VOTE WAIT	0 days — bypassed
NETWORK DOWNTIME	None
MECHANISM	Atomic bridge upgrade on L1

The exact four moves that *recovered* $70M.

Kelp's recovery wasn't magic — it was the council's powers used surgically. This slide shows how *upgrade · impersonate · transfer · revert* compose into a single transaction that no pure-DAO governance model could have authored in time.

Step 01

Upgrade.

`inbox.upgradeTo(temp)`

Temporarily replace the Ethereum→Arbitrum bridge implementation with a custom one.

Step 02

Impersonate.

`sendL2Msg(hacker)`

Inject a function that forges cross-chain messages as if sent by the hacker's address.

Step 03

Transfer.

`eth.transfer(30_766)`

Move 30,766 ETH from the hacker's Arbitrum wallet to a DAO-controlled recovery address.

Step 04

Revert.

`inbox.upgradeTo(orig)`

Restore the bridge to its original implementation. Backdoor closed in the same transaction.

All four steps, *one atomic transaction* — no window for collateral damage.

$70M+ SAVED · ZERO DOWNTIME

The council model has *its own* attack surface.

01 · ECONOMIC

Flash loan governance attack.

An attacker borrows massive voting power in one block, passes a malicious proposal, and repays the loan. If council reaction lags or timelocks don't guard flash votes, the DAO is legally hijacked in seconds.

02 · OPERATIONAL

Key compromise honeypot.

Concentrating control in 12 signers creates a single high-value target. A sophisticated actor — state-sponsored or otherwise — who compromises signer devices inherits the protocol.

03 · LEGAL

Subpoena & coercion.

Council members are known individuals with the power to freeze or move assets. That makes them uniquely vulnerable to subpoenas, sanctions, and direct regulatory pressure.

04 · PHILOSOPHICAL

Decentralization theater.

If 9 people can impersonate any user and seize funds — even for good reasons — is the network actually decentralized? The trust model quietly shifts from *trust the code* back to *trust these humans*.

Every council is a *bet* on which failure mode you'd rather survive.

SIDE A · PURE DECENTRALIZATION

Censorship *resistance*.

— No humans to coerce, subpoena, or compromise.

— Fully trustless — the code is the only authority.

— Fatal to speed: a 7-day timelock is a 7-day drain.

SIDE B · COUNCIL MODEL

Rapid *response*.

— Instant emergency intervention — minutes, not days.

— Proven recovery of funds mid-exploit.

— Trust shifts back to identifiable humans with keys.

Trust the *code*, or trust the *keys*.

PART I	Pure decentralization cannot outrun its own bugs.
PART II	Councils are the industry's pragmatic answer — a handbrake with god-mode keys.
PART III	Kelp DAO proved the model works: $70M+ recovered, zero downtime.
PART IV	The handbrake is also a honeypot. The trust model has moved — not disappeared.